

README — KIT DE ENCUESTA CIA TRIAD

Guía de Uso, Instalación y Estructura del Kit Completo

CIA Triad Survey Kit v2025 • Diagnóstico de Madurez en Ciberseguridad



ÍNDICE DE ESTE README

1. ¿Qué es este Kit?
2. Estructura de archivos
3. Cómo usar el Kit (guía rápida)
4. Guía de implementación paso a paso
5. Audiencias y perfiles de uso
6. Bases normativas y fuentes
7. Sistema de métricas: el IGM-CIA
8. Personalización y adaptación
9. Control de versiones
10. Créditos y licencia de uso
11. Glosario rápido
12. Preguntas frecuentes

1. ¿QUÉ ES ESTE KIT?

El **CIA Triad Survey Kit** es un instrumento de diagnóstico integral diseñado para evaluar la **madurez operativa en las tres dimensiones del marco CIA Triad** —Confidencialidad, Integridad y Disponibilidad— en organizaciones de cualquier sector y tamaño, con especial foco en el contexto español y europeo.

Este kit no es un cuestionario de cumplimiento documental. Es un **instrumento de conocimiento organizacional** que combina:

- ✓ Evidencia empírica de los informes de referencia global más recientes (2025)
- ✓ Ancla normativa directa con ENS, NIS2, DORA, ISO 27001, NIST CSF 2.0
- ✓ Un sistema de puntuación estandarizado (IGM-CIA) comparable entre organizaciones
- ✓ Herramientas de análisis financiero (ROI/ROSI) para comunicación con el Consejo
- ✓ Un tono que respeta la inteligencia del lector sin sacrificar la precisión técnica

¿Para qué sirve?

Uso	Descripción	Beneficiario
Autodiagnóstico	Una organización evalúa su propia postura CIA	CISO / CIO / DPO
Investigación sectorial	Múltiples organizaciones para análisis comparativo	Investigadores / Consultores
Auditoría interna	Evaluación periódica del estado de controles	Auditoría interna / Compliance
Benchmarking	Comparativa entre pares del mismo sector	Asociaciones sectoriales / ENISA
Comunicación ejecutiva	Presentar el estado de seguridad al Consejo	CISO / Comité de Riesgos
Formación	Material de base para programas de concienciación	Responsables de formación

2. ESTRUCTURA DE ARCHIVOS

📁 CIA_Triad_Survey_Kit_2025/	
— 📄 README.md	← Este archivo (empezar aquí)
— 📄 CIA-encuesta-integral.md	← (a) Modelo de encuesta completa
— Bloques 0-8 60+ preguntas Escala Likert + opciones múltiples	
— 📄 CIA-guia-metodologica.md	← (b) Guía metodológica detallada
— Diseño muestral Administración Codificación Análisis estadístico	
— 📄 CIA-narrativa-explicativa.md	← (c) El porqué de cada pregunta
— Contexto empírico Relevancia estratégica Evidencia 2025	
— 📄 CIA-mapeo-normativo.md	← (d) Mapeo pregunta → normativa
— ENS NIS2 DORA ISO 27001 NIST RGPD EU AI Act eIDAS 2	
— 📄 CIA-plantilla-excel-IGM-ROI.md	← (e) Especificación Excel
— IGM-CIA ROSI FAIR Dashboard Benchmarking sectorial	
— 📄 CIA-reporte-ejecutivo-pptx.md	← (f) Especificación PowerPoint
— 18 diapositivas Consejo de Administración Métricas ejecutivas	
— 📄 README.md	← (g) Este documento
— Guía completa de uso del kit	

3. CÓMO USAR EL KIT (GUÍA RÁPIDA)

Para un autodiagnóstico organizacional (30 minutos):

1. Lee la encuesta (CIA-encuesta-integral.md)
2. Responde honestamente (el único enemigo aquí es la autocomplacencia)
3. Codifica las respuestas con la tabla de CODIFICACION (plantilla Excel)
4. Calcula el IGM-CIA
5. Identifica las alertas críticas automáticas
6. Genera el informe ejecutivo con la plantilla PowerPoint
7. Prioriza acciones con la matriz impacto/esfuerzo

Para un estudio de investigación (semanas):

1. Lee la Guía Metodológica completa
2. Define el diseño muestral (estratificado, $n \geq 300$)
3. Configura la plataforma de encuesta (LimeSurvey recomendado)
4. Implementa los 60+ ítems de CIA-encuesta-integral.md
5. Recoge datos en el período de campo
6. Importa respuestas en la plantilla Excel
7. Ejecuta análisis estadístico (ANOVA, correlaciones, ACP)
8. Redacta informe con la estructura de reporte ejecutivo

4. GUÍA DE IMPLEMENTACIÓN PASO A PASO

FASE 1: PREPARACIÓN (Semana 1)

Paso 1.1 — Seleccionar la plataforma de encuesta

Plataforma	RGPD	Coste	Funciones	Recomendación
LimeSurvey (self-hosted)	✓ Óptimo	Gratuito	Avanzadas	🏆 Mejor para investigación
Google Forms	⚠ Revisar DPA	Gratuito	Básicas	✓ Opción económica
Microsoft Forms	✓ Con tenant EU	Corporativo	Intermedias	✓ Entornos corporativos
SurveyMonkey	⚠ USA CLOUD	Pago	Avanzadas	⚠ Verificar DPA
Qualtrics	✓ Con acuerdo	Pago	Investigación	🏆 Investigación académica

Paso 1.2 — Implementar la encuesta

Copiar los ítems de CIA-encuesta-integral.md en la plataforma elegida, respetando:

- El tipo de pregunta (opción única ☐ / selección múltiple ☐ / texto libre)
- El orden de los bloques (0 – 8)
- Las instrucciones de bloque al inicio de cada sección
- La declaración de consentimiento al final

Paso 1.3 — Configurar la lógica de ramificación (opcional)

Para encuestas a organizaciones no sujetas a ENS:

- Ocultar P0.5 y preguntas específicas ENS
- Adaptar las referencias normativas en el texto de las preguntas

Para organizaciones del sector financiero:

- Destacar preguntas DORA (P3.1-3.4, P3.7, P3.9, P5.1, P5.3)
- Añadir sección específica TLPT si la organización es entidad significativa

Paso 1.4 — Prueba piloto

Aplicar el cuestionario a 10-15 perfiles representativos:

- Verificar tiempo real de cumplimentación (objetivo: 45-60 min)
- Identificar preguntas ambiguas o técnicamente imprecisas para el perfil encuestado
- Calcular el Alfa de Cronbach preliminar por bloque (objetivo $\alpha > 0.70$)

FASE 2: TRABAJO DE CAMPO (Semanas 2-4)

Paso 2.1 — Comunicación de captación

Plantilla de correo de invitación recomendada:

Asunto: [Organización/Proyecto] – Diagnóstico CIA Triad: Su participación importa

Estimado/a [Nombre],

En el marco del [proyecto/estudio/iniciativa], le invitamos a participar en el Diagnóstico de Madurez CIA Triad 2025, un instrumento de evaluación de las prácticas de ciberseguridad en organizaciones del sector [sector].

Su tiempo estimado de respuesta: 45-60 minutos.

Las respuestas son anónimas y se tratan conforme al RGPD.

Recibirá [informe agregado / benchmarking sectorial] como retribución.

Acceder a la encuesta: [URL]

Plazo de respuesta: [fecha]

Para cualquier duda técnica: [contacto]

[Firma]

Paso 2.2 — Gestión de la tasa de respuesta

- Día 0: Envío inicial
- Día 7: Primer recordatorio (tono cordial: "Su perspectiva es valiosa")
- Día 14: Segundo recordatorio (tono más directo + refuerzo del incentivo)
- Día 18: Cierre de campo

Paso 2.3 — Control de calidad de respuestas en tiempo real

Verificar semanalmente:

- Tiempo de cumplimentación < 10 minutos – probablemente respuesta superficial (excluir)

- Respuestas lineales (siempre la misma opción en toda la encuesta) → sesgo (excluir)
- Perfil del respondente no válido → eliminar y reemplazar

FASE 3: ANÁLISIS Y REPORTE (Semanas 5-8)

Paso 3.1 — Importar datos a la plantilla Excel

Ver instrucciones detalladas en CIA-plantilla-excel-IGM-ROI.md.

Paso 3.2 — Calcular IGM-CIA

La fórmula central:

$$IGM_CIA = (w_C \times IGM_C) + (w_I \times IGM_I) + (w_A \times IGM_A)$$

Donde las ponderaciones w se obtienen de la tabla sectorial en la hoja PONDERACIONES.

Paso 3.3 — Identificar alertas críticas

Revisar la columna "Alertas_Críticas" en IGM_CALC. Cada alerta roja requiere:

- Descripción del riesgo
- Acción de remediación inmediata
- Responsable asignado
- Plazo máximo

Paso 3.4 — Generar el reporte ejecutivo

Seguir la estructura de CIA-reporte-ejecutivo-pptx.md:

- 18 diapositivas + apéndices
- Datos del Excel → Diapositivas 4-10
- Plan de acción → Diapositivas 13-15
- Métricas de seguimiento → Diapositiva 16

5. AUDIENCIAS Y PERFILES DE USO

Perfil	Documentos prioritarios	Sección clave
CISO / Responsable Seguridad	Todos	Encuesta + Mapeo normativo
CIO / CTO	Encuesta + Excel + PowerPoint	Bloques 3, 5, 7 + ROI
DPO	Encuesta + Mapeo normativo	Bloque 1 (Confidencialidad) + RGPD
Responsable Cumplimiento	Mapeo normativo + PowerPoint	Bloque 5 + Diapositivas 11
Auditor interno	Guía metodológica + Mapeo	Sección 5 (análisis estadístico)
Investigador / Consultor	Guía metodológica + Excel	Secciones 2, 4 y 5 de la guía
Consejo de Administración	Reporte ejecutivo (PowerPoint)	Diapositivas 2, 4, 10, 13, 17
Responsable formación	Narrativa explicativa	Bloque 6 (cultura)

6. BASES NORMATIVAS Y FUENTES

Marco normativo de referencia

Normativa	Ámbito	Estado en España (Abril 2026)	Sanciones
ENS (RD 311/2022)	AAPP y proveedores	Vigente	Administrativa
NIS2 (UE 2022/2555)	Sectores esenciales	Anteproyecto LCGC aprobado enero 2025	Hasta 10M€ o 2% facturación
DORA (UE 2022/2554)	Sector financiero	Vigente desde 17/01/2025	Según supervisor (BDE/CNMV)
RGPD (UE 2016/679)	Universal	Vigente	Hasta 20M€ o 4% facturación
EU AI Act (UE 2024/1689)	Sistemas IA	En aplicación por fases	Hasta 35M€ o 7% facturación
eIDAS 2 (UE 2024/1183)	Identidad digital	En implementación	Según supervisor

Fuentes de datos empíricos utilizados

Fuente	Año	Datos utilizados	URL referencia
INCIBE Balance de Ciberseguridad	2025	122.223 incidentes, 237.028 sistemas vulnerables	incibe.es
ENISA Threat Landscape	2025	4.875 incidentes EU, vectores de ataque	enisa.europa.eu
ENISA NIS Investments	2025	1.080 profesionales, 1,5M€ presupuesto mediano	enisa.europa.eu
IBM Cost of Data Breach	2025	\$4,44M coste medio, 241 días lifecycle	ibm.com/security
Verizon DBIR	2025	22.052 incidentes, 44% ransomware	verizon.com/dbir
Cisco Cybersecurity Readiness Index	2025	Solo 4% organizaciones nivel Mature	cisco.com
FAIR Institute State of CRM	2025	45% adopción modelo FAIR	fairinstitute.org
Aon Cyber Risk Report España	2025	+5% mejora controles, -7% primas	aon.com
ITU Global Cybersecurity Index	2024	España Tier 1, 99,74/100	itu.int
FSB Peer Review España	2025	Recomendaciones sector financiero	fsb.org

7. SISTEMA DE MÉTRICAS: EL IGM-CIA

El **Índice Global de Madurez CIA (IGM-CIA)** es la métrica central del kit.

Fórmula

$$\text{IGM_CIA} = (w_C \times P_C) + (w_I \times P_I) + (w_A \times P_A)$$

Donde:

- P_C, P_I, P_A = Puntuaciones medias de cada pilar (escala 1-5)
- w_C, w_I, w_A = Ponderaciones sectoriales (suman 1.0)

Escala de interpretación

IGM-CIA	Nivel	Color	Acción
1.0 - 1.9	● Crítico	Rojo	Plan de emergencia
2.0 - 2.9	● Deficiente	Naranja	Plan de mejora (6 meses)
3.0 - 3.9	● En desarrollo	Amarillo	Hoja de ruta (12 meses)
4.0 - 4.4	● Competente	Azul	Optimización
4.5 - 5.0	★ Líder	Morado	Compartir conocimiento

Alertas automáticas (independientes del IGM)

Las siguientes respuestas generan ALERTA ROJA sin importar la puntuación global:

- Cuentas de administrador compartidas sin rotación
- Algoritmos legacy (3DES, MD5, SHA-1) en cifrado de datos
- Sin proceso de parcheo definido para vulnerabilidades críticas
- Sin BCP formal
- Detección de incidentes solo por notificación de usuarios
- Desconocimiento de requisitos de notificación NIS2/DORA

8. PERSONALIZACIÓN Y ADAPTACIÓN

Adaptación por sector

Para sectores con requisitos normativos adicionales, añadir los siguientes módulos opcionales:

Sector financiero (DORA):

- Módulo TLPT (Threat-Led Penetration Testing)
- Preguntas específicas sobre clasificación de incidentes ICT
- Gestión de proveedores TIC críticos (Art. 28 DORA)

Administración Pública (ENS):

- Módulo de categorización de sistemas
- Preguntas sobre uso CCN-STIC (guías aplicables)
- Interoperabilidad y sistemas de autenticación Cl@ve

Sector salud:

- Módulo dispositivos médicos (EU MDR + ciberseguridad)
- Preguntas específicas protección datos de salud (Categoría especial RGPD)

Sector industrial / OT:

- Módulo ICS/SCADA específico
- Preguntas IEC 62443
- Segmentación IT/OT

Adaptación idiomática

El instrumento está diseñado para español de España (es-ES). Para adaptaciones:

- **Latinoamérica:** Ajustar referencias normativas (sustituyendo ENS por marcos nacionales equivalentes)
- **Inglés:** Traducción directa disponible bajo solicitud
- **Português:** Compatible con adaptación al contexto LGPD (Brasil)

9. CONTROL DE VERSIONES

Versión	Fecha	Cambios principales	Autores
v1.0	Ene 2023	Versión inicial (CIA clásico, 35 preguntas)	—
v1.5	Jun 2024	Añadidos módulos DORA y NIS2, NIST CSF 2.0	—
v2.0	Dic 2024	Rediseño completo, 60+ preguntas, IGM-CIA	—
v2.1	Abr 2026	Actualización datos 2025, PQC, Shadow AI, AI Act	—

Frecuencia de revisión recomendada: Anual (las métricas de referencia se actualizan con los informes anuales de INCIBE, ENISA, IBM, Verizon)

10. CRÉDITOS Y LICENCIA DE USO

Instrumento basado en:

- NIST Cybersecurity Framework 2.0 (2024) — dominio público
- ENS Real Decreto 311/2022 — dominio público (BOE)
- ISO/IEC 27001:2022 — ISO (uso referencial, no reproducción)
- ENISA Threat Landscape 2025 — Creative Commons BY 4.0
- IBM Cost of Data Breach Report 2025 — uso referencial
- Verizon DBIR 2025 — uso referencial
- FAIR Institute — uso referencial

Licencia de uso del instrumento:

Creative Commons BY-SA 4.0 (Atribución - CompartirIgual)

Condiciones:

-  Uso libre para investigación académica, consultora y formación
-  Adaptación permitida con atribución al kit original
-  Uso comercial permitido con atribución
-  No se permite eliminar la atribución normativa y de fuentes
-  No se permite presentar como instrumento propio sin atribución

11. GLOSARIO RÁPIDO

Término	Definición
CIA Triad	Confidentiality, Integrity, Availability — el triángulo fundamental de la seguridad de la información
CIANA	Extensión de CIA con Non-repudiation y Authenticity
IGM-CIA	Índice Global de Madurez CIA — puntuación compuesta 1-5
MTTD	Mean Time to Detect — tiempo medio de detección de incidentes
MTTR	Mean Time to Respond — tiempo medio de respuesta
MTTC	Mean Time to Contain — tiempo medio de contención
RTO	Recovery Time Objective — tiempo máximo de inactividad tolerable
RPO	Recovery Point Objective — pérdida máxima de datos tolerable
ROSI	Return on Security Investment — retorno sobre la inversión en seguridad
ALE	Annualized Loss Expectancy — pérdida esperada anualizada (modelo FAIR)
FIM	File Integrity Monitoring — monitorización de integridad de ficheros
PAM	Privileged Access Management — gestión de accesos privilegiados
DLP	Data Loss Prevention — prevención de pérdida de datos
SBOM	Software Bill of Materials — inventario de componentes de software
PQC	Post-Quantum Cryptography — criptografía resistente a ataques cuánticos
HNDL	Harvest Now, Decrypt Later — captura de datos para descifrado futuro
ENS	Esquema Nacional de Seguridad (RD 311/2022)
NIS2	Directiva de Seguridad de Redes e Información v2 (UE 2022/2555)
DORA	Digital Operational Resilience Act (UE 2022/2554)
FAIR	Factor Analysis of Information Risk — modelo de cuantificación de riesgo
GQM	Goal-Question-Metric — metodología de diseño de métricas

CMMI	Capability Maturity Model Integration — modelo de madurez de procesos
SOC	Security Operations Center — centro de operaciones de seguridad
SIEM	Security Information and Event Management
Zero Trust	Arquitectura de seguridad "nunca confiar, siempre verificar"

12. PREGUNTAS FRECUENTES

¿Es obligatorio responder todas las preguntas?

No. Las preguntas de selección múltiple y texto libre son opcionales. Las preguntas de escala (1-5) son necesarias para el cálculo del IGM-CIA.

¿Puedo adaptar las preguntas a mi sector?

Sí, con las indicaciones de la Sección 8 (Personalización). Respetar siempre el anclaje normativo de cada pregunta documentado en CIA-mapeo-normativo.md.

¿Cuántas organizaciones necesito para un estudio estadísticamente válido?

Mínimo 300 (margen de error $\pm 5,6\%$, NC 95%). Óptimo 500. Ver Sección 2 de la Guía Metodológica.

¿El kit es válido para una PYME sin CISO dedicado?

Absolutamente. Las preguntas están calibradas para todos los perfiles. Una PYME sin CISO puede ser respondida por el responsable de TI o el gerente con responsabilidad tecnológica.

¿Con qué frecuencia debería repetirse el diagnóstico?

Semestral para seguimiento de mejoras; anual para benchmarking sectorial y actualización de referencias. Siempre tras un incidente significativo.

¿Qué hago si mi organización obtiene IGM-CIA < 2.0?

Activar protocolo de alerta: comunicación inmediata al Consejo, plan de remediación de emergencia (90 días), priorizar las alertas críticas automáticas. No hay respuesta técnicamente incorrecta en la encuesta; solo el no actuar sobre los resultados lo es.

¿El kit está alineado con el ENS?

Sí, explícitamente. Ver columna "Marco Principal" en CIA-mapeo-normativo.md. Las cinco dimensiones del ENS (confidencialidad, integridad, disponibilidad, autenticidad, trazabilidad) están cubiertas.

¿Es compatible con ISO 27001:2022?

Sí. Los controles del Anexo A de ISO 27001:2022 están mapeados en CIA-mapeo-normativo.md para todas las preguntas relevantes.

CONTACTO Y SOPORTE

Para consultas sobre el instrumento, adaptaciones sectoriales o colaboración en investigación:

 [contacto del equipo investigador]
 [web del proyecto, si aplica]
 Repositorio: [URL repositorio si es open source]
 Última actualización: Abril 2026

*"El conocimiento de la propia vulnerabilidad es el primer activo de ciberseguridad.
Todo lo demás es consecuencia de esa honestidad inicial."*

— CIA Triad Survey Kit Team, 2025

Versión: 2.1.0 (Abril 2026)
Licencia: Creative Commons BY-SA 4.0
Estado: Estable · Activamente mantenido
Idioma: Español (es-ES)